



UNIVERSIDADE FEDERAL DE SANTA CATARINA
CENTRO TECNOLÓGICO
PROGRAMA DE PÓS-GRADUAÇÃO EM CIÊNCIA DA COMPUTAÇÃO

Luciano Figueiredo Coelho

**Hybrid Cryptographic Security Protocols for the Brazilian Open Insurance
Ecosystem: Structural Analysis, Threat Modeling, and Post-Quantum Transition
Framework**

Florianópolis
2026

Luciano Figueiredo Coelho

**Hybrid Cryptographic Security Protocols for the Brazilian Open Insurance
Ecosystem: Structural Analysis, Threat Modeling, and Post-Quantum Transition
Framework**

Seminário de Andamento de Doutorado apresentado ao Programa de Pós-Graduação em Ciência da Computação da Universidade Federal de Santa Catarina como requisito parcial do curso de doutorado, na linha de pesquisa Segurança em Sistemas Computacionais.

Orientador: Prof. Dr. Ricardo Felipe Custódio

Coorientador: Prof. Dr. Martin Augusto Gagliotti Vigil

Florianópolis

2026

ABSTRACT

The Brazilian Open Insurance ecosystem operates over a security architecture whose guarantees of authenticity, integrity, confidentiality, and non-repudiation depend structurally on classical public-key cryptographic primitives, specifically RSA and ECDHE, whose security rests on mathematical problems solvable in polynomial time by Shor's algorithm. This dependency is normatively mandated across all mandatory operational flows of the ecosystem, from institutional onboarding to the revocation of compromised credentials. The harvest now, decrypt later (HNDL) vector renders this exposure operationally relevant in the present, independently of temporal horizons for the availability of sufficient quantum capability. The research problem is the absence of a post-quantum cryptography transition framework structurally compatible with the causal chain of cryptographic dependencies of Open Insurance, with the normative instruments governing the ecosystem, and with the distinct update cycles of its participants. The methodological approach combines structural analysis of the ecosystem's mandatory operational flows, modelling of quantum exposure by cryptographic primitive dependency, and experimental validation through prototyping and performance evaluation. Two partial results have been obtained. The first is a systematic review of the open paradigm, published in July 2025, which characterises security as a structural condition for the remaining pillars of mature open ecosystems. The second, with manuscript in final stages of development, maps the security baseline of Open Insurance, demonstrating that nine of the eleven mandatory operational steps depend structurally on classical primitives, and proposes a transition framework comprising a three-tier migration urgency taxonomy, a phased hybrid transition model, and six normative extension requirements for ICP-Brasil and the Open Insurance Participant Directory. The work is structured over the four-year horizon of the doctoral programme: the Doctoral Progress Seminar takes place in June 2026, the Qualification Examination is scheduled for February 2027, and the thesis defence for August 2028.

Keywords: Open Insurance. Post-Quantum Cryptography. Hybrid Protocols. FAPI. ICP-Brasil. HNDL.

LIST OF FIGURES

Figure 1 – Causal security flow of the Brazilian OPIN ecosystem. 10

Figure 2 – Quantum-induced cascade failure in the OPIN trust chain. 18

LIST OF TABLES

Table 1 – Quantum exposure mapping by OPIN operational step.	16
Table 2 – Research timeline.	32

LIST OF ABBREVIATIONS AND ACRONYMS

BRCAC	Brazilian Certificate for Authentication Channel
BRSEAL	Brazilian Certificate for Signing
CNSP	Conselho Nacional de Seguros Privados
CRL	Certificate Revocation List
DCR	Dynamic Client Registration
ECDHE	Elliptic Curve Diffie-Hellman Ephemeral
ECDLP	Elliptic Curve Discrete Logarithm Problem
ENISA	European Union Agency for Cybersecurity
EQD	Exame de Qualificação de Doutorado
FAPI	Financial-grade API
FIPS	Federal Information Processing Standards
HNDL	Harvest Now, Decrypt Later
ICPBrasil	ICP-Brasil – Infraestrutura de Chaves Públicas Brasileira
IETF	Internet Engineering Task Force
IFP	Integer Factorization Problem
JWE	JSON Web Encryption
JWT	JSON Web Token
LGPD	Lei Geral de Proteção de Dados
MLDSA	ML-DSA – Module Lattice-based Digital Signature Algorithm
MLKEM	ML-KEM – Module Lattice-based Key Encapsulation Mechanism
MLWE	Module Learning With Errors
mTLS	Mutual Transport Layer Security
NIST	National Institute of Standards and Technology
OCSP	Online Certificate Status Protocol
OIDC	OpenID Connect
OPIN	Open Insurance Brasil
PKI	Public Key Infrastructure
PQC	Post-Quantum Cryptography
RSA	Rivest-Shamir-Adleman
SAD	Seminário de Andamento de Doutorado
SLHDSA	SLH-DSA – Stateless Hash-based Digital Signature Algorithm
SSA	Software Statement Assertion
SUSEP	Superintendência de Seguros Privados
TLS	Transport Layer Security

CONTENTS

1	INTRODUCTION	7
1.1	THE OPEN PARADIGM AND THE BRAZILIAN OPEN INSURANCE .	7
1.2	IDENTITY, AUTHORISATION, AND OPERATIONAL FLOWS	8
1.3	CRYPTOGRAPHIC INFRASTRUCTURE AND SECURITY STANDARDS	12
1.4	THE QUANTUM THREAT AND THE HNDL VECTOR	13
1.5	RESEARCH GAP	20
1.6	RESEARCH PROBLEM	21
1.7	RESEARCH QUESTIONS	21
1.8	OBJECTIVES	22
2	BACKGROUND	24
2.1	NIST PQC STANDARDS AND ALGORITHMIC FAMILIES	24
2.2	HYBRID CRYPTOGRAPHY AS A TRANSITION STRATEGY	25
2.3	CRYPTO-AGILITY	26
3	SOLUTION APPROACH	28
3.1	THREE-TIER MIGRATION URGENCY TAXONOMY	28
3.2	PHASED HYBRID TRANSITION MODEL	29
3.3	NORMATIVE EXTENSION REQUIREMENTS	29
3.4	EXPERIMENTAL VALIDATION	30
4	PARTIAL RESULTS AND RESEARCH TIMELINE	31
4.1	PARTIAL RESULTS OBTAINED	31
4.2	RESEARCH TIMELINE	32
	References	33

1 INTRODUCTION

The Brazilian Open Insurance ecosystem operates over a distributed trust architecture in which security is not a property of isolated components, but a systemic outcome of the coherent articulation of normative mandates, institutional processes, and mandatory cryptographic enforcement mechanisms. The sections of this chapter contextualise the research problem, characterise the structural dependence of the ecosystem on classical public-key cryptography, identify the relevant quantum threat vectors, delimit the research gap, formulate the research problem and the questions that guide the investigation, and establish the specific objectives of the work.

1.1 THE OPEN PARADIGM AND THE BRAZILIAN OPEN INSURANCE

The progressive digitalisation of financial and insurance services has produced, over the past decade, large-scale interoperable ecosystems in which data, services, and operational capabilities are shared among independent institutions under common regulatory frameworks (Open Insurance Brasil, 2021e). Initiatives such as Open Banking, Open Finance, and Open Insurance have consolidated interaction models based on standardised interfaces, consent-mediated data sharing, and institutionalised trust relationships, with the objective of fostering competition, innovation, and consumer empowerment in digital infrastructures that process highly sensitive data.

The systematic literature review conducted by Coelho, Custódio, and Matos (2025) on the evolutionary frameworks of the open paradigm identified five pillars that characterise mature open ecosystems: inclusion, interoperability, innovation, security, and consumer empowerment. These pillars are not independent of one another. Security, in particular, is a structural condition for the others: without adequate cryptographic guarantees, interoperability becomes a vector of exposure and data portability a systemic risk.

In Brazil, Open Insurance refers to the regulated sharing of insurance data and services among independent institutions through standardised interfaces, mediated by explicit consumer consent. The ecosystem, referred to as OPIN, was formally established by CNSP Resolution No. 415/2021 (Conselho Nacional de Seguros Privados (CNSP), 2021) and operationalised by SUSEP Circular No. 635/2021 (Superintendência de Seguros Privados (SUSEP), 2021a), which define the governance arrangements, participation requirements, and security controls governing data sharing among participants. The ecosystem encompasses insurers, brokers, and insurance service initiators operating under common rules, with data sharing conditioned on explicit consent granted by the data subject, the policyholder or insurance customer whose data are the object of sharing operations.

At the centre of the ecosystem's trust architecture stands the Participant Di-

rectory, operated under Superintendência de Seguros Privados (SUSEP) supervision. Before any operational interaction can take place, an institution seeking to access data, referred to as a *receiver*, must register with the Directory and obtain a Software Statement Assertion (SSA), a signed credential that certifies its institutional identity and the permissions assigned to it by the Directory (Open Insurance Brasil, 2021d, 2021a). When the receiver subsequently approaches a data-holding institution, the *transmitter*, it presents this Software Statement Assertion (SSA) as cryptographic proof of legitimacy. The transmitter, in turn, holds digital certificates issued under the Brazilian Public Key Infrastructure (ICP-Brasil – Infraestrutura de Chaves Públicas Brasileira (ICPBrasil)) that authenticate its identity in the transport channel and in the messages it signs (Open Insurance Brasil, 2021c; Superintendência de Seguros Privados (SUSEP), 2022). In this model, trust between receiver and transmitter is established not through prior bilateral agreement, but through shared reliance on two external anchors: the Participant Directory and ICPBrasil.

The cryptographic infrastructure that underpins this model relies on a set of classical public-key primitives whose security rests on the computational difficulty of two mathematical problems: the factorisation of large integers, exploited by Rivest-Shamir-Adleman (RSA), and the computation of discrete logarithms over elliptic curves, exploited by Elliptic Curve Diffie-Hellman Ephemeral (ECDHE). These problems are the foundation upon which the security protocols of the ecosystem, namely OAuth 2.0 (Hardt, 2012), OpenID Connect (OIDC) (Jones; Bradley; Sakimura, 2014), and the Financial-grade API (FAPI) profile (OpenID Foundation, 2021), impose their guarantees of authenticity, integrity, confidentiality, and non-repudiation. This dependency is explicitly mandated in the normative instruments and technical specifications governing OPIN (Open Insurance Brasil, 2022; Superintendência de Seguros Privados (SUSEP), 2022), and its implications for the long-term security of the ecosystem constitute the central concern of this research.

1.2 IDENTITY, AUTHORISATION, AND OPERATIONAL FLOWS

Identity in Open Insurance Brasil (OPIN) is not limited to the identification of end users. This section examines the mandatory operational flows of the ecosystem from an institutional perspective: who the actors are, which artefacts they produce and consume, and in what order operations are chained. The technical analysis of the cryptographic primitives that underpin each step is the object of Section 1.3.

Identity in OPIN encompasses primarily institutions, applications, and services that interact within the ecosystem, constituting an institutional and technical identity model in which participants are represented by cryptographic credentials issued and validated under shared rules, enabling interoperable trust relationships among independent entities (Open Insurance Brasil, 2022, 2021a). This model is anchored in

ICPBrasil, under which digital certificates are issued that bind institutions and applications to public keys recognised by the ecosystem (Open Insurance Brasil, 2021c; Superintendência de Seguros Privados (SUSEP), 2022). The certificates serve distinct and complementary functions: transport certificates (Brazilian Certificate for Authentication Channel (BRCAC)) authenticate Transport Layer Security (TLS) channels between systems through Mutual Transport Layer Security (mTLS); signing certificates (Brazilian Certificate for Signing (BRSEAL)) guarantee the authenticity and non-repudiation of messages, tokens, and artefacts exchanged among participants. This functional separation is deliberate and aligned with security best practices in regulated environments, aimed at isolating critical functions and reducing attack surfaces (Open Insurance Brasil, 2022).

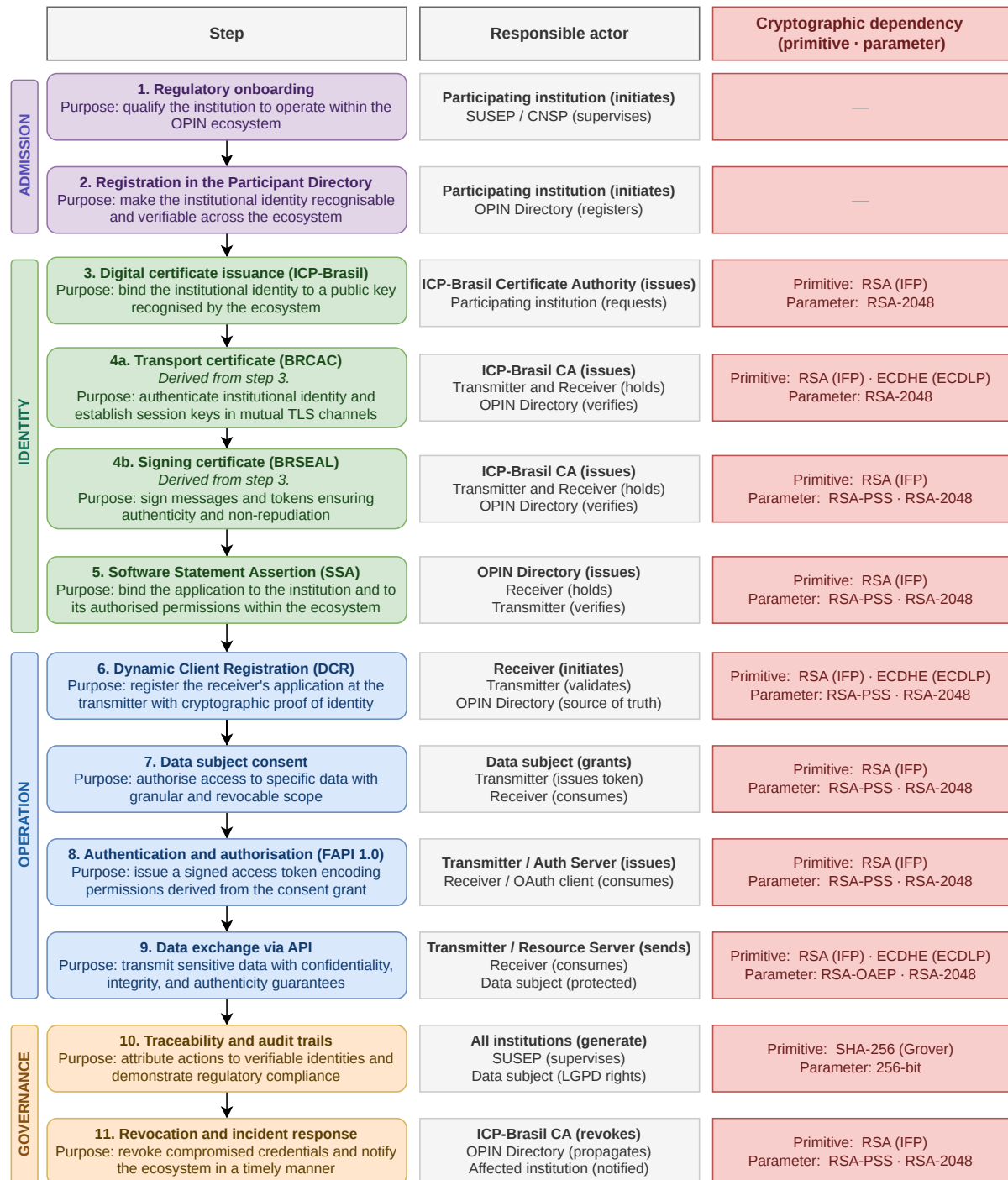
Authorisation is implemented through access tokens issued according to OAuth 2.0 flows and the Financial-grade API (FAPI) profile, which materialise access decisions derived from scopes, consents, and defined policies. A specific governance artefact, the SSA, plays a central role in this model: it is a JSON Web Token (JWT) issued and signed by the Participant Directory that certifies, in a cryptographically verifiable manner, that a given application belongs to a registered institution and has received specific permissions to operate within the ecosystem. When a receiver wishes to connect to a transmitter for the first time, it presents its SSA as proof that it is a legitimate and authorised entity, without the two institutions requiring any prior relationship. Trust is mediated by the Directory, which signs the SSA making it verifiable by any participant (Open Insurance Brasil, 2021d, 2021a).

The actors involved in the operational flows are the following:

- the participating institutions in their roles as transmitters and receivers;
- the data subject whose consent conditions access;
- the Participant Directory as the ecosystem's trust authority;
- ICPBrasil as the root certification infrastructure; and
- SUSEP as the supervising authority.

Figure 1 presents these flows in an integrated manner, mapping for each of the eleven mandatory steps the responsible actor and, where applicable, the cryptographic primitive on which that step depends.

Figure 1 – Causal security flow of the Brazilian OPIN ecosystem.



Source: Elaborated by the author.

The flow begins in the admission phase. In step 1, the candidate institution undergoes regulatory onboarding against the normative framework established by Conselho Nacional de Seguros Privados (CNSP) Resolution No. 415/2021 (Conselho Nacional de Seguros Privados (CNSP), 2021), SUSEP Circular No. 635/2021 (Superintendência de Seguros Privados (SUSEP), 2021a), and SUSEP Circular No. 638/2021 (Su-

perintendência de Seguros Privados (SUSEP), 2021b), which define respectively the framework, the operational standards, and the cybersecurity requirements applicable to participating societies. In step 2, the institution registers with the Participant Directory, which records its identity and makes it recognisable and verifiable across the ecosystem (Open Insurance Brasil, 2021a). These two steps do not incorporate cryptographic primitives directly, but establish the normative conditions that govern the execution of all subsequent steps.

In the cryptographic identity phase, step 3 marks the institution's entry into the ecosystem's chain of trust: ICPBrasil's Certificate Authority issues a digital certificate that binds the institution's identity to a public key recognised by the ecosystem, establishing the Public Key Infrastructure (PKI) chain from which the operational certificates of steps 4a and 4b are issued in parallel, each instantiating a distinct cryptographic primitive (Open Insurance Brasil, 2021c). In step 4a, the BRCAC is issued with two primitives whose functional roles are, respectively, to authenticate the institution's identity in the mTLS handshake and to derive the ephemeral shared secrets from which session keys are established. In step 4b, the BRSEAL is issued to sign messages, tokens, and artefacts exchanged among participants, guaranteeing their authenticity and non-repudiation. In step 5, the Directory issues the SSA, a JWT token that provides the cryptographic guarantee of authenticity and non-repudiation for the binding of the receiver's application to its institutional identity and the permissions assigned to it (Open Insurance Brasil, 2021a, 2021d). These three artefacts, BRCAC, BRSEAL, and SSA, constitute the pillars of technical identity in the ecosystem and are a prerequisite for any subsequent operation.

In the operation phase, the receiver presents its SSA to the transmitter to carry out Dynamic Client Registration (DCR), the process by which an application formally registers with another institution to obtain credentials for accessing its APIs. DCR is executed over an mTLS channel authenticated by BRCAC certificates, and the SSA serves as cryptographic proof that the registering application is recognised and authorised by the Directory. The data subject then grants consent through an OpenID Connect (OIDC) flow, resulting in the issuance of an identity token signed by the transmitter. Based on this consent, the transmitter's Authorisation Server issues the access token that materialises the derived permissions. The effective data exchange occurs over a TLS 1.2/1.3 channel (Rescorla, 2018), with JSON Web Encryption (JWE) envelopes guaranteeing confidentiality and integrity of messages (Open Insurance Brasil, 2022; Superintendência de Seguros Privados (SUSEP), 2022).

In the continuous governance phase, audit trails record and attribute each action to verifiable identities. The revocation mechanism operates through Certificate Revocation List (CRL) and Online Certificate Status Protocol (OCSP) responses signed by ICPBrasil's Certificate Authority, allowing compromised certificates to be revoked

and the information propagated to the ecosystem by the Participant Directory (Superintendência de Seguros Privados (SUSEP), 2022). It is important to distinguish step 11 from step 3: while both involve ICPBrasil, their operational roles are fundamentally distinct. In step 3, ICPBrasil acts in its identity issuance capacity, binding an institution's public key to a certificate. In step 11, it acts in its governance and incident response capacity, signing CRL documents and OCSP responses to communicate certificate status to the ecosystem (Superintendência de Seguros Privados (SUSEP), 2022; Open Insurance Brasil, 2021a).

The analysis of these flows reveals two structurally relevant patterns. The first is the causal nature of the chain: the compromise of a primitive at any step propagates to the following steps that depend on the cryptographic properties guaranteed by that primitive, such that failures are not localised but cascade through the operational chain. The second is the concentration of dependencies: of the eleven mandatory steps, nine incorporate classical public-key primitives or hash-based primitives as structural conditions of functioning. The technical nature of these primitives and the mathematical problems that underpin their security are the object of the following section.

1.3 CRYPTOGRAPHIC INFRASTRUCTURE AND SECURITY STANDARDS

This section examines the cryptographic infrastructure of OPIN from a technical perspective, describing the primitives, parameters, and mathematical problems that underpin each functional layer of the operational flows presented in Section 1.2.

The security model of OPIN is built on a layered architecture inherited from international secure interoperability initiatives developed within the OpenID Foundation (Jones; Bradley; Sakimura, 2014; OpenID Foundation, 2021), which were progressively adopted as the normative basis of the ecosystem, defining a structure in which authorisation, authentication, and additional security mechanisms are organised in a progressively more restrictive manner.

At the base of this architecture, OAuth 2.0 (Hardt, 2012) provides the authorisation mechanisms required for controlled API access, defining standardised flows for the issuance and use of access tokens. Built on this foundation, OpenID Connect introduces authentication and identity verification capabilities, allowing access requests to be associated with verifiable identities through standardised claims. The FAPI profile (OpenID Foundation, 2021) imposes additional security requirements designed for regulated environments, including mandatory secure communication, certificate-based mutual authentication, and reinforced protections against known classes of attacks targeting authorisation flows and token handling.

From the perspective of cryptographic infrastructure, this dependency entails the widespread adoption of public-key cryptography mechanisms, the use of digital certificates issued by recognised authorities under ICPBrasil, and the application of

TLS-based secure transport protocols (Rescorla, 2018). The authorisation and authentication layer mandates RSA-PSS with SHA-256, referred to as PS256, as the signing primitive for access tokens, identity tokens, and request objects, as required by the OAuth 2.0, OIDC, and FAPI specifications adopted as the normative basis of the ecosystem (Open Insurance Brasil, 2022). The FAPI profile additionally requires certificate-based mutual authentication for all API interactions, binding each channel to the RSA-2048 public key of the communicating institution. At the institutional identity layer, transport certificates (BRCAC) depend on RSA-2048 and on ECDHE, which derives the ephemeral shared secrets from which session keys are established in the mutual TLS (mTLS) handshake. Signing certificates (BRSEAL) have RSA-2048 as their underlying public-key primitive, with RSA-PSS applied to sign messages, tokens, and artefacts exchanged among participants, guaranteeing their authenticity and non-repudiation. This functional separation between channel authentication and message signing is deliberate, aimed at isolating critical functions and reducing attack surfaces (Open Insurance Brasil, 2022; Superintendência de Seguros Privados (SUSEP), 2022). At the data confidentiality layer, RSA-OAEP performs key encapsulation in JWE envelopes, with AES-256-GCM providing symmetric content encryption, and SHA-256 underpins the integrity of audit records and signed logs (Superintendência de Seguros Privados (SUSEP), 2022).

The security of these primitives rests on the computational difficulty of two mathematical problems: the Integer Factorization Problem (Integer Factorization Problem (IFP)), on which RSA-2048, RSA-OAEP, and RSA-PSS depend, and the Elliptic Curve Discrete Logarithm Problem (Elliptic Curve Discrete Logarithm Problem (ECDLP)), on which ECDHE depends (Bernstein; Buchmann; Dahmen, 2009). These are precisely the problems for which Shor's algorithm (Shor, 1997) provides a polynomial-time solution on a sufficiently capable quantum computer, making the cryptographic infrastructure of OPIN structurally exposed to the quantum threat model. The precise extent of this exposure, however, can only be assessed through a systematic analysis of the mandatory operational flows of the ecosystem, which is the object of the following section.

1.4 THE QUANTUM THREAT AND THE HNDL VECTOR

This section examines the resilience of the OPIN security model against the quantum threat model. The analysis does not presuppose the current existence of quantum computers capable of compromising production systems, nor does it define temporal horizons for such a scenario. It adopts instead the perspective consolidated by Mosca (2018), according to which quantum exposure must be evaluated by the relationship between the lifetime of the data a system protects, the time required for cryptographic migration, and the estimated time until relevant quantum capability becomes

available, and by NIST SP 1800-38B (National Institute of Standards and Technology, 2023), which recommends initiating migration processes with sufficient lead time to accommodate technical and regulatory complexities. The analysis that follows examines the present conditions that determine the extent of that risk.

The derivation of the security properties compromised at each step of the OPIN operational flow follows a direct logic grounded in established results from the quantum cryptography literature. For RSA-based primitives, including PS256 and RSA-OAEP, Shor's algorithm (Shor, 1997) allows the private key to be derived from the corresponding public key, granting the adversary functional access equivalent to that of the legitimate key holder: indistinguishable signatures can be forged and any message encrypted with the associated public key decrypted (Bernstein; Buchmann; Dahmen, 2009). The properties of authenticity, non-repudiation, and confidentiality cease to be guaranteed. For ECDHE, Proos and Zalka (Proos; Zalka, 2003) demonstrated that the extension of Shor's algorithm to elliptic curves allows the secret exponent to be derived from the public values exchanged in the key agreement protocol, enabling a quantum adversary to recompute session keys for any intercepted TLS session, compromising confidentiality retroactively.

For SHA-256, Grover's algorithm (Grover, 1996) reduces the pre-image search complexity from $O(2^{256})$ to $O(2^{128})$, halving the effective security of the hash function. Banegas *et al.* (2021) and NIST (National Institute of Standards and Technology, 2024c) observe that 128 bits of effective security represent an insufficient margin for systems whose records must remain intact and verifiable for decades, as is the case for OPIN's audit trails under long-term regulatory retention obligations.

The distinction between the impacts of Shor's algorithm and Grover's algorithm is analytically relevant because it implies distinct urgency horizons. Shor's algorithm produces a complete and immediate compromise of the affected primitives: once a quantum computer of sufficient capability becomes available, RSA and ECDHE cease to offer any security guarantee. Grover's algorithm, by contrast, produces a partial degradation: SHA-256 retains 128 bits of effective security, which does not represent an immediate failure but constitutes an insufficient margin for systems with long-term retention obligations. This asymmetry underpins the distinction between Level 1 and Level 3 components in the migration framework proposed in Chapter 3 (detailed in Section 3.2): not only does the nature of the threat differ, but so does the temporal window within which migration is necessary.

A specific characteristic of the quantum threat model in PKI infrastructures, identified by Bernstein, Buchmann, and Dahmen (2009), is that compromise does not need to occur at the moment of credential use. An adversary with access to a quantum computer can retroactively compromise any certificate whose public key was observed at any prior point, including expired or revoked certificates, provided the corresponding

traffic records have been preserved. In the context of OPIN, this implies that the integrity of signatures produced under the classical model cannot be guaranteed retroactively, since the corresponding private key can be derived from any public key observed in intercepted traffic (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997).

NIST SP 1800-38B (National Institute of Standards and Technology, 2023) categorises systems by Post-Quantum Cryptography (PQC) migration urgency based on two combined factors: the operational criticality of the processed data and the quantum sensitivity of the algorithms in use. OPIN satisfies both criteria with high intensity: it processes data of high regulatory criticality under SUSEP supervision, including sensitive personal data protected by the Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), and operates entirely over algorithms with direct quantum sensitivity. European Union Agency for Cybersecurity (ENISA), in its report on post-quantum cryptography (European Union Agency for Cybersecurity (ENISA), 2021), classifies regulated financial infrastructures with multiple institutional participants and national PKI dependence as systems of maximum priority for immediate initiation of inventory and migration planning processes. OPIN satisfies this classification on all relevant criteria.

Based on the results of Shor (Shor, 1997), Bernstein et al. (Bernstein; Buchmann; Dahmen, 2009), Proos and Zalka (Proos; Zalka, 2003), and Grover (Grover, 1996), it is possible to map, in a traceable manner, for each step of the OPIN operational flow that presents a classical cryptographic dependency, which security property ceases to be guaranteed under the quantum threat model. Table 1 presents this mapping.

The table reveals that of the eleven mandatory operational steps, nine present cryptographic dependencies directly affected by the quantum threat model. The two steps without direct cryptographic dependency, regulatory onboarding and Directory registration, retain their formal validity, but lose their practical meaning when the artefacts produced by subsequent steps can no longer be trusted.

Three aspects of the table merit close attention. The first is the diversity of the compromised properties: exposure does not concentrate on confidentiality, a property frequently associated with cryptography in the narrow sense, but equally affects authenticity, integrity, and non-repudiation, which are the properties on which the ecosystem's capacity to attribute responsibilities, audit actions, and enforce regulatory obligations rests (Open Insurance Brasil, 2021d). The second aspect is the position of the most critical steps in the chain: steps 3, 4a, and 4b are located in the cryptographic identity phase, which precedes all ecosystem operations, constituting the foundations on which everything else is built. A quantum adversary who compromises any one of these three steps does not need to attack the operational flows individually: the trust infrastructure that makes those flows verifiable has already been undermined at its root. The third aspect concerns step 11: the CRL/OCSP-based revocation mechanism operates over

Table 1 – Quantum exposure mapping by OPIN operational step.

Step	Primitive	Quantum alg.	Compromised property
3. ICP-Brasil cert.	RSA-2048	Shor	Institutional identity authenticity (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997)
4a. BRCAC	RSA-2048 ECDHE	Shor	TLS channel confidentiality (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997; Proos; Zalka, 2003)
4b. BRSEAL	RSA-PSS · RSA-2048	Shor	Message authenticity and non-repudiation (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997)
5. SSA	RSA-PSS · RSA-2048	Shor	App–institution binding authenticity (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997)
6. DCR	RSA-2048 ECDHE	Shor	Client registration authenticity (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997; Proos; Zalka, 2003)
7. Consent (OIDC)	RSA-PSS · RSA-2048	Shor	Consent authenticity and integrity (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997)
8. Access token (FAPI)	RSA-PSS · RSA-2048	Shor	Authorisation authenticity and integrity (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997)
9. Data exchange	RSA-OAEP ECDHE	Shor	Transmitted data confidentiality (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997; Proos; Zalka, 2003)
10. Audit trails	SHA-256	Grover	Long-term record integrity and immutability (National Institute of Standards and Technology, 2024c; Grover, 1996; Banegas <i>et al.</i> , 2021)

Source: Compiled by the author (Bernstein; Buchmann; Dahmen, 2009; Shor, 1997; Grover, 1996; Proos; Zalka, 2003; Banegas *et al.*, 2021).

RSA signatures from the PKI itself, meaning that the instrument designed to respond to cryptographic compromises is itself affected by the same class of threat it is meant to mitigate, a transitive dependency that Bernstein, Buchmann, and Dahmen (2009) identify as a structural fragility pattern in PKI infrastructures.

The causal nature of the OPIN operational chain implies that quantum exposure does not manifest as a set of independent and localised vulnerabilities. Bernstein, Buchmann, and Dahmen (2009) argue that, in systems where trust is built on a certification chain, the compromise of one link does not produce a contained failure, but invalidates the guarantees of all elements that depend on that link for their verifiability. In OPIN, this transitive dependency runs through the entire operational chain: the ability to derive

private keys from ICPBrasil certificates, afforded by Shor's result (Shor, 1997), enables the issuance of forged BRCAC and BRSEAL certificates; forged certificates enable fraudulent SSAs; fraudulent SSAs enable unauthorised DCRs; and unauthorised DCRs allow the obtainment of apparently valid access tokens, with the entire flow formally correct from the perspective of operational controls, which continue verifying signatures and certificates whose mathematical foundations have been compromised.

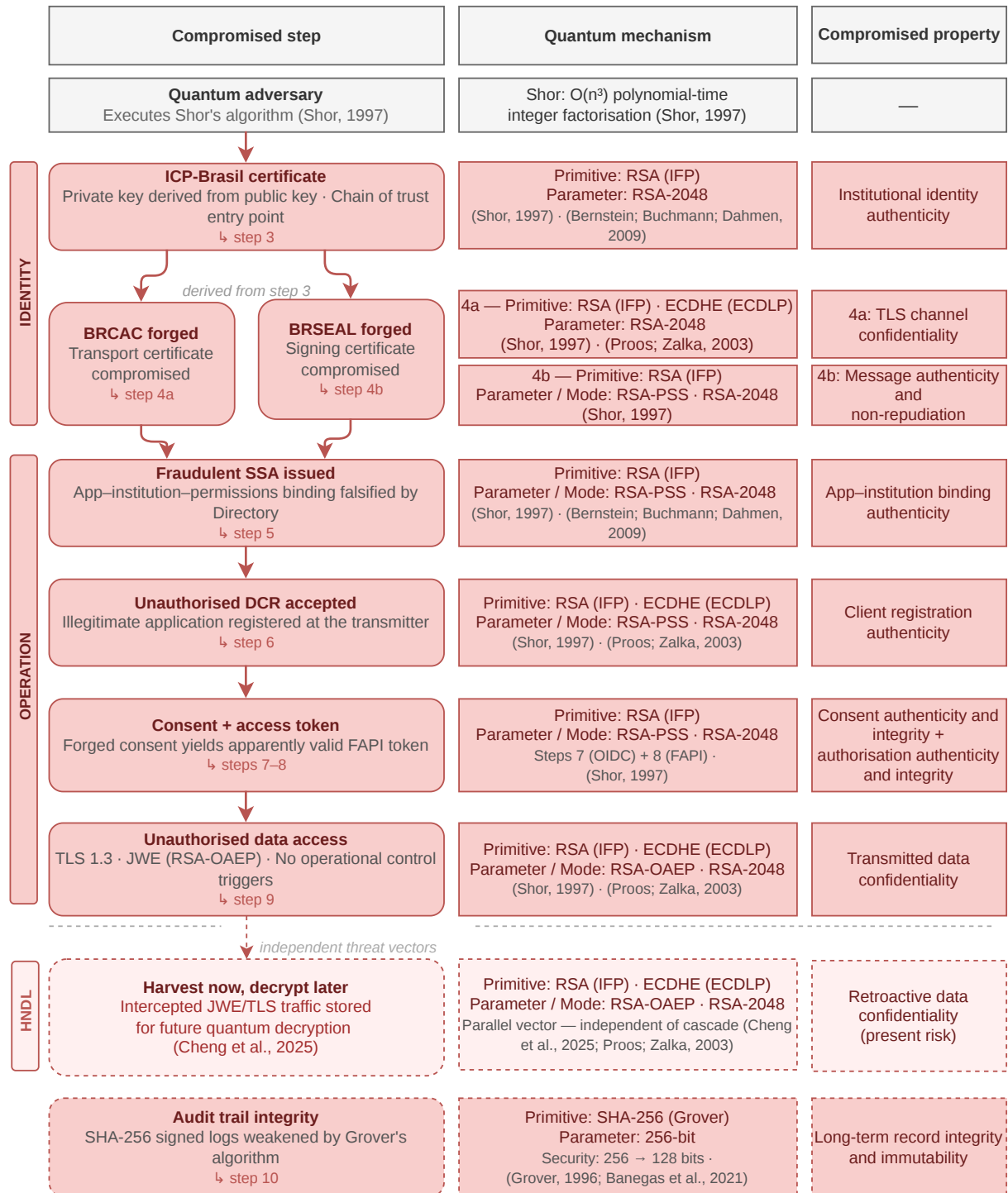
This propagation pattern distinguishes quantum exposure from conventional vulnerabilities, which typically admit localised responses. A conventional compromise of a single participant's credentials can be contained through revocation and re-issuance. A quantum compromise of the underlying cryptographic assumptions, however, affects all participants simultaneously and cannot be contained through the same revocation mechanisms, since those mechanisms are themselves based on the compromised primitives (Bernstein; Buchmann; Dahmen, 2009). NIST SP 1800-38B (National Institute of Standards and Technology, 2023) observes that, in distributed PKI infrastructures, the compromise of a root certification authority invalidates the entire chain of trust that depends on it, and that the distributed architecture which confers operational capability on the ecosystem simultaneously amplifies the reach of any failure in the cryptographic assumptions that sustain it.

The significance of this propagation pattern lies not only in its technical scope, but in its operational invisibility. In conventional security incidents, anomalous behaviour typically produces detectable signals: failed authentication attempts, unexpected access patterns, or certificate validation errors. A quantum compromise of the foundational cryptographic layer produces none of these signals, because the adversary operates with cryptographic credentials that are indistinguishable from legitimate ones. The ecosystem's monitoring and audit mechanisms, which rely on the same primitives that have been compromised, cannot distinguish a forged SSA from an authentic one, nor a fraudulent access token from a legitimately issued one. This invisibility is what makes the quantum threat categorically different from the threat models that the current security controls of OPIN were designed to address (Bernstein; Buchmann; Dahmen, 2009; National Institute of Standards and Technology, 2023).

Figure 2 represents this progression in a structured manner. For each step in the cascade, the diagram identifies the compromised cryptographic mechanism in the central column and the security property that ceases to be guaranteed as a direct consequence in the right column. The vertical reading of the figure makes observable what the text describes: none of the steps produces a detectable alert signal from the ecosystem's operational controls, because those controls depend on the same cryptographic primitives that were compromised in the initial step. The Grover vector and the HNDL vector, shown in the bottom rows with dashed borders, are deliberately separated from the cascade to make their distinct nature evident: neither depends on

the execution of the chain above. The Grover vector operates independently over audit trail integrity, while the HNDL vector operates in parallel over traffic already in circulation, making the present risk independent of any future active compromise event.

Figure 2 – Quantum-induced cascade failure in the OPIN trust chain.



Source: Elaborated by the author.

The Harvest Now, Decrypt Later (HNDL) vector introduces a temporal dimen-

sion that makes OPIN's quantum exposure relevant in the present. It is important to note that HNDL does not target data at rest: it targets data in transit. An adversary intercepts and stores encrypted network traffic today, specifically TLS sessions and JWE-encrypted API messages, and retains it until a quantum computer capable of running Shor's algorithm becomes available. At that point, the adversary derives the session keys retroactively and decrypts the previously captured traffic. The data that becomes exposed may well reside in long-lived records such as insurance policies or audit trails, but the attack vector is the transmission channel, not the storage layer.

Mosca (2018) formalised this risk through an inequality relating the lifetime of the data (X), the time required for cryptographic migration (Y), and the time until relevant quantum capability becomes available (Z): when $X + Y > Z$, the system is already exposed to HNDL risk, regardless of when Z will materialise. Cheng *et al.* (2025) modelled this risk quantitatively for sectors with high-retention data, demonstrating that delays in PQC migration directly amplify the exposure window of already-collected data, and that this amplification is irreversible, since captured traffic cannot be retroactively protected by migrations carried out after its interception. In OPIN, data categories with extended lifecycles include insurance policies and their endorsement histories, open supplementary pension records, consent data and its temporal traceability, and audit trails preserved for regulatory supervision purposes. For these categories, Mosca's inequality (Mosca, 2018) may already be violated considering the typical confidentiality horizons of the insurance sector and the time historically required for cryptographic migrations in regulated infrastructures with multiple interdependent systems (National Institute of Standards and Technology, 2023; Campbell, 2025).

The limits of OPIN's current security model can now be precisely identified. These limits do not stem from design flaws or regulatory non-compliance: the adopted mechanisms are in full conformity with the applicable normative instruments, including the LGPD (Brasil, 2018), and reflect the cryptographic state of the art at the time of their specification. The problem, as pointed out by Bernstein, Buchmann, and Dahmen (2009), is of a different nature: the adopted mechanisms are temporally conditioned on a computational paradigm whose validity cannot be assumed indefinitely. A system can be correct with respect to its technical and normative specifications and, simultaneously, structurally exposed to a class of threats for which it was not designed (Mosca, 2018). In the case of OPIN, this exposure manifests on two distinct planes: on the future operational plane, an adversary with quantum capability could forge identities, tokens, and signatures, compromising the integrity of all ecosystem flows; on the present retroactive plane, the HNDL vector implies that long-lived data transmitted under classical protection is already potentially subject to collection for future decryption (Mosca, 2018; Cheng *et al.*, 2025). NIST SP 1800-38B (National Institute of Standards and Technology, 2023) observes that the absence of observable operational failures is precisely the

condition that makes proactive assessment most necessary in high-criticality systems: when the threat becomes observable, the moment to initiate migration has already passed. It is on this structural urgency that the research gap identified in the following section is grounded.

1.5 RESEARCH GAP

The exposure of regulated financial ecosystems to quantum threats has received growing attention in the literature, yet no existing work addresses the full causal chain of cryptographic dependencies that characterises interoperable insurance ecosystems with national PKI. The works examined below establish the state of this literature and delimit the gap this research proposes to fill.

Sadeghi *et al.* (2025) conducted a systematic evaluation of the performance and practicality of NIST-selected post-quantum algorithms for financial sector applications, including EMV, 3D Secure, and TLS-based systems, concluding that ML-DSA – Module Lattice-based Digital Signature Algorithm (MLDSA) and SLH-DSA – Stateless Hash-based Digital Signature Algorithm (SLHDSA) offer adequate computational efficiency for signing operations in financial environments. However, the study does not examine the normative and interoperability constraints of regulated ecosystems with multiple institutional participants, nor does it address the chain of cryptographic dependencies that characterises consent-oriented ecosystems.

Schardong *et al.* (2022) proposed adaptations to OAuth 2.0 and OpenID Connect for the post-quantum setting, demonstrating that OIDC implementations based on MLDSA achieve performance equivalent to the classical model in low-latency scenarios. The study does not, however, address the FAPI profile or the certification constraints imposed by national public-key infrastructures.

Campbell (2025) analysed timelines and strategic frameworks for enterprise migration to the post-quantum model, quantifying migration durations of five to fifteen or more years depending on enterprise size, without addressing the specificities of regulated insurance ecosystems.

Giron *et al.* (2024) evaluated the impact of PQC migration on the Automatic Certificate Management Environment (ACME) protocol for automated digital certificate issuance, proposing a new challenge mechanism that reduces the issuance time of PQC and hybrid certificates by up to 4.22x compared to the standard HTTP-01 method. The study, however, addresses certificate issuance infrastructure in a generic context, without examining the normative constraints specific to regulated ecosystems such as OPIN, or the causal chain of dependencies that conditions any migration strategy in such environments.

None of these works examines the causal chain of cryptographic dependencies that characterises interoperable insurance ecosystems, in which regulatory onboard-

ing, certification under ICPBrasil, application registration, data subject consent, FAPI authorisation, and continuous traceability constitute mandatory and sequentially dependent steps, each subject to normative constraints that condition any migration strategy. The absence of studies that structurally characterise this model and propose transition strategies compatible with its regulatory, institutional, and interoperability constraints constitutes the gap this research proposes to fill.

1.6 RESEARCH PROBLEM

The analysis developed in the preceding sections establishes that the Brazilian Open Insurance ecosystem operates over a security architecture whose guarantees of authenticity, integrity, confidentiality, and non-repudiation depend structurally on classical public-key primitives (RSA and ECDHE), whose security rests on mathematical problems solvable in polynomial time by Shor's algorithm (Shor, 1997). This dependency is not incidental: it is normatively mandated across all mandatory operational flows of the ecosystem, from certificate issuance under ICPBrasil to the revocation of compromised credentials. The HNDL vector renders this exposure operationally relevant in the present, independently of temporal horizons for the availability of sufficient quantum capability (Mosca, 2018; Cheng *et al.*, 2025).

The research problem of this work is the following: the absence of a post-quantum cryptography transition framework that is structurally compatible with the causal chain of cryptographic dependencies of OPIN, with the normative constraints of the instruments that govern the ecosystem, and with the distinct update cycles of its participants, prevents cryptographic migration from being conducted in an orderly, interoperable, and regulatorily valid manner, leaving the ecosystem exposed to quantum compromise vectors for which its current response mechanisms are structurally inadequate.

1.7 RESEARCH QUESTIONS

The research problem formulated in the preceding section guides the investigation through the following questions:

- RQ1.** What are the structural cryptographic dependencies of the OPIN ecosystem, which primitives instantiate them at each mandatory operational step, and which security properties cease to be guaranteed under the quantum threat model, including the HNDL vector?
- RQ2.** How should the components of the ecosystem be prioritised for post-quantum migration, considering the irreversible nature of the HNDL vector and the lifecycle of the data protected at each operational step?

- RQ3.** How should a hybrid transition model be structured to preserve interoperability among participants at distinct stages of migration, respecting the heterogeneous update cycles of the ecosystem's distributed architecture?
- RQ4.** Which normative extensions are required in the instruments governing OPIN and ICPBrasil for post-quantum migration to be regulatorily valid within the existing governance architecture?
- RQ5.** Do the proposed hybrid mechanisms introduce operational overhead compatible with the performance requirements of the ecosystem's authorisation and data exchange flows?

1.8 OBJECTIVES

This research has as its general objective the development of a post-quantum cryptography transition framework adapted to the regulatory, institutional, and interoperability constraints of the Brazilian Open Insurance ecosystem, integrating classical and post-quantum cryptography in a manner compatible with its distributed architecture and capable of protecting its operations against present and future classical and quantum threats.

The specific objectives are as follows:

- SO1.** To characterise the structural security baseline of OPIN, making explicit the cryptographic dependencies, trust coupling points, and normative assumptions present in its mandatory operational flows.
- SO2.** To map the structural exposure of this baseline to the quantum threat model, identifying which security properties cease to be guaranteed at each affected operational step, including the HNDL vector.
- SO3.** To propose a PQC migration urgency taxonomy that classifies the ecosystem's components according to the nature of the threat affecting them and the lifecycle of the data they protect, distinguishing components subject to the HNDL vector from those subject to prospective compromise.
- SO4.** To design a phased hybrid transition model that operationalises the migration sequence derived from the taxonomy proposed in SO3, preserving interoperability among participants at distinct stages of migration through the concurrent operation of classical and post-quantum cryptographic mechanisms.
- SO5.** To derive normative extension requirements for ICPBrasil and the OPIN Participant Directory from the applicable regulatory instruments themselves.
- SO6.** To validate the proposed mechanisms experimentally through prototyping and performance evaluation on representative operational flows of the ecosystem, following the methodology established by Giron *et al.* (2024).

The characterisation of the problem established in this chapter, together with the objectives derived from it, presupposes a body of knowledge spanning two distinct domains: the post-quantum cryptographic standards and transition mechanisms that constitute the analytical framework of the research, and the existing literature on quantum threats to regulated financial ecosystems that delimits the gap identified above. Chapter 2 examines both domains, establishing the state of the art on which the solution approach proposed in Chapter 3 is built.

2 BACKGROUND

This chapter presents the body of knowledge that underpins the research developed in this work, constituting the state of the art on which the contributions of this work are grounded. It covers the post-quantum cryptographic standards and transition mechanisms that constitute the analytical framework applied in the structural analysis of Chapter 1 and the solution approach proposed in Chapter 3: the National Institute of Standards and Technology (NIST)-standardised algorithms, the hybrid cryptography model, and the crypto-agility principle.

2.1 NIST PQC STANDARDS AND ALGORITHMIC FAMILIES

Following a global evaluation process initiated in 2016, NIST published in August 2024 the first three federal post-quantum cryptography standards (National Institute of Standards and Technology, 2024a, 2024b, 2024c). These standards do not constitute a generic replacement of classical algorithms, but a structured response to specific cryptographic functions: key encapsulation, high-frequency digital signatures, and signatures for long-lived artefacts. The distinction among these functions is relevant to the OPIN context, where the compromised primitives identified in Chapter 1 belong precisely to these three categories.

Federal Information Processing Standards (FIPS) 203 specifies ML-KEM – Module Lattice-based Key Encapsulation Mechanism (MLKEM), a key encapsulation mechanism whose security rests on the Module Learning With Errors (MLWE) problem (National Institute of Standards and Technology, 2024a). MLKEM operates exclusively at the key encapsulation layer, with symmetric content encryption remaining the responsibility of algorithms such as AES-256-GCM, and is resistant to Shor’s algorithm because Module Learning With Errors (MLWE) does not belong to the class of problems that Shor’s algorithm solves (Shor, 1997; Bernstein; Buchmann; Dahmen, 2009). The functions that MLKEM is designed to perform correspond directly to those of RSA-OAEP in key encapsulation operations and to those of ECDHE in ephemeral key establishment protocols (National Institute of Standards and Technology, 2024a).

FIPS 204 specifies MLDSA, a digital signature scheme equally grounded in the MLWE problem (National Institute of Standards and Technology, 2024b). MLDSA is designed to perform the functions of RSA-PSS in message, token, and certificate signing operations. Empirical studies in regulated financial environments demonstrate that MLDSA-based implementations achieve performance equivalent to the classical model in low-latency scenarios (Schardong *et al.*, 2022; Sadeghi *et al.*, 2025), which supports their operational viability in high-frequency authorisation and consent flows.

FIPS 205 specifies SLHDSA, a digital signature scheme based exclusively on hash functions, without reliance on lattice problems (National Institute of Standards and

Technology, 2024c). This choice of mathematical foundation confers more conservative security guarantees on SLHDSA: its quantum resistance does not depend on the soundness of MLWE, but on the resistance of hash functions to exhaustive search, for which Grover’s algorithm (Grover, 1996) represents a moderate and well-understood threat. At the cost of larger signature sizes, SLHDSA is indicated for contexts in which signatures must remain valid over extended periods and in which certainty about the soundness of the scheme outweighs size considerations.

The three standards serve complementary and non-competing functions. MLKEM is the central mechanism for confidentiality and key establishment; MLDSA is the primary candidate for digital signatures in high-frequency flows; SLHDSA is the conservative alternative for long-lived artefacts. For the purposes of this work, the mapping between these standards and the cryptographic dependencies identified in Chapter 1 is direct: MLKEM is the functional candidate to replace RSA-OAEP in JWE envelopes and ECDHE in TLS session establishment (National Institute of Standards and Technology, 2024a); MLDSA is the functional candidate to replace PS256 in JWT, SSA, and access token signatures, and RSA-PSS in BRSEAL certificates (National Institute of Standards and Technology, 2024b); and SLHDSA is a natural candidate for root certificate renewal under ICPBrasil and for the protection of long-retention audit trails (National Institute of Standards and Technology, 2024c). SHA-256, treated as a Level 3 component in the framework proposed in Chapter 3, may be addressed through migration to SHA-384 to maintain 192 bits of effective security under Grover’s algorithm (Grover, 1996; Banegas *et al.*, 2021).

2.2 HYBRID CRYPTOGRAPHY AS A TRANSITION STRATEGY

The direct replacement of classical algorithms with post-quantum algorithms in regulated and interoperable ecosystems is not feasible in the short term. The new algorithms have accumulated a relatively limited history of cryptanalytic scrutiny compared to RSA and elliptic-curve-based schemes, and their immediate and generalised adoption would break interoperability with participants still operating under current standards. The approach recommended by NIST (National Institute of Standards and Technology, 2023), ENISA (European Union Agency for Cybersecurity (ENISA), 2021), and the Internet Engineering Task Force (IETF) (Stebila; Fluhrer; Gueron, 2025) for the transition period is hybrid cryptography: the simultaneous combination of a classical algorithm and a post-quantum algorithm in the same cryptographic operation, such that the security of the result depends on the resistance of both.

In practical terms, a hybrid signature concatenates the classical signature, such as PS256, with the post-quantum signature, such as MLDSA, over the same content. A hybrid key encapsulation combines the secret derived from ECDHE with the secret derived from MLKEM, using both as input for the final symmetric key derivation (Stebila;

Fluhrer; Gueron, 2025). This model ensures that, while the transition is ongoing, an adversary with quantum capability gains no advantage, as they would need to break the post-quantum component simultaneously, and that a classical adversary equally gains no advantage, as they would need to break the classical component. The resulting security is therefore at least as strong as that of the stronger algorithm in the pair (Bernstein; Buchmann; Dahmen, 2009; National Institute of Standards and Technology, 2023).

For OPIN, hybrid cryptography is especially relevant because the ecosystem operates over a chain of trust distributed among multiple independent institutions. Migration cannot be coordinated simultaneously across all participants: transmitters, receivers, the Participant Directory, and ICPBrasil operate under distinct update cycles and regulatory and contractual constraints that require formal validation before any modification to certification standards (Open Insurance Brasil, 2022; Superintendência de Seguros Privados (SUSEP), 2021a). The hybrid model allows participants at different levels of PQC maturity to interoperate securely during the transition period, without the migration of one participant forcing the immediate migration of all others (National Institute of Standards and Technology, 2023; Stebila; Fluhrer; Gueron, 2025).

2.3 CRYPTO-AGILITY

Beyond the adoption of specific algorithms, the literature on PQC migration in highly regulated environments converges on an architectural principle known as crypto-agility: the capacity of a system to replace cryptographic primitives without structural redesign (National Institute of Standards and Technology, 2023; Bernstein; Buchmann; Dahmen, 2009). In ecosystems such as OPIN, where algorithms are normatively defined in versioned technical documents, crypto-agility implies that both the technical architecture and the normative framework are designed to accommodate cryptographic evolution in a controlled manner. This includes the explicit separation between the specification of security functions, such as authentication, confidentiality, and integrity, and the specification of the algorithms that implement them, so that replacing an algorithm does not alter the functional requirements of the ecosystem.

On the technical dimension, crypto-agility requires that participants' implementations parametrise algorithm identifiers such that their update does not require changes to the underlying business logic. Systems that incorporate algorithm identifiers rigidly in code or infrastructure configurations will require more substantial intervention at the time of migration, with greater cost and operational risk. As Campbell (2025) documents, the ability to update cryptographic primitives in a controlled manner without structural system redesign is a determinant factor in the speed and cost of migrations in regulated environments.

On the normative dimension, crypto-agility implies that OPIN's regulatory instru-

ments be revised not only to include the currently standardised PQC algorithms, but in a manner that establishes an agile update mechanism for cryptographic parameters for future revisions (National Institute of Standards and Technology, 2023). The current model, in which supported algorithms are defined in versioned documents with a formal revision process, is appropriate for guaranteeing stability and predictability, but may be complemented by a simplified cryptographic parameter update mechanism reserved exclusively for additions or removals of algorithms from the supported set. Rigidity in update processes is one of the main factors of delay in PQC migrations in regulated environments (Campbell, 2025), and its mitigation has a direct impact on the ecosystem's capacity to respond agilely to future developments.

3 SOLUTION APPROACH

This chapter presents the solution approach developed in the scope of this research. The first section proposes a migration urgency taxonomy that classifies the ecosystem's components according to the nature of the threat affecting them and the lifecycle of the data they protect. The second section describes the phased hybrid transition model that operationalises the resulting migration sequence. The third section derives the normative extension requirements for the migration to be regulatorily valid within the ecosystem's governance architecture. The fourth section presents the experimental methodology that will guide the validation of the proposed mechanisms.

3.1 THREE-TIER MIGRATION URGENCY TAXONOMY

The prioritisation of PQC migration in OPIN cannot be determined solely by the operational criticality of the components, since this perspective ignores the temporal asymmetry introduced by the HNDL vector. As demonstrated in Chapter 1, the irreversibility of HNDL consequences imposes a qualitatively distinct prioritisation criterion: components whose retroactive compromise is possible must be treated with greater urgency than their immediate operational criticality would indicate, regardless of when relevant quantum capability becomes available. This principle, derived from Mosca's inequality (Mosca, 2018) and the guidelines of NIST SP 1800-38B (National Institute of Standards and Technology, 2023), is the central axis of the proposed taxonomy.

The classification of components considers two combined criteria: the nature of the cryptographic property at risk, retroactive confidentiality affected by HNDL versus prospective authenticity and integrity affected by the future capacity to forge signatures; and the lifecycle of the protected data or artefacts. The combination of these criteria produces three urgency levels that are not merely risk categories, but concrete guidelines for migration sequencing. Level 1 encompasses the data-in-transit encryption mechanisms, namely ECDHE in TLS session establishment and RSA-OAEP in JWE envelopes, whose consequences of delayed migration are irreversible. Level 2 encompasses the digital signature mechanisms, PS256 in JWT tokens, SSA, and BRSEAL certificates, and the institutional authentication dimension of BRCAC certificates, whose compromise is prospective but of maximum systemic severity. It is important to distinguish that the ECDHE mechanism used by BRCAC for session establishment belongs to Level 1, while its institutional authentication dimension based on RSA-2048 belongs to Level 2. Level 3 encompasses SHA-256, whose partial degradation by Grover's algorithm (Grover, 1996) does not represent an immediate failure but constitutes an insufficient margin for systems with long-term retention obligations.

3.2 PHASED HYBRID TRANSITION MODEL

The taxonomy proposed in the preceding section addresses the prioritisation question, but not the execution question: how should a structured migration be conducted in a distributed, regulated ecosystem with multiple participants operating at distinct rhythms? The proposed phased transition model addresses this question, with hybrid cryptography as its central mechanism.

The operational structure of the framework combines three forms of sequencing that must not be conflated. The first is the serial relationship between phases: the three phases are strictly sequential, since each depends on preconditions established by the preceding one. The second is the parallel relationship among components within Phase 2: the urgency levels do not constitute a serial execution queue, allowing institutions to work simultaneously on Level 1 and Level 2 components with resource allocation proportional to urgency. The third is the parallel operation within each individual hybrid cryptographic mechanism: when ECDHE and MLKEM operate in hybrid mode, both execute simultaneously over the same input, with the final secret derived from the combination of both results (Stebila; Fluhrer; Gueron, 2025).

Phase 1 involves inventory, assessment, and preparation, with no changes to algorithms in operation. Phase 2 introduces hybrid operation across all Level 1 and Level 2 taxonomy components, ensuring that each step of the OPIN operational flow offers protection resistant to quantum adversaries without breaking interoperability with participants still in the migration process. Phase 3 consolidates exclusively PQC operation, with progressive removal of classical algorithms from hybrid pairs as universal compatibility is confirmed, operationalising the crypto-agility principle defined in Section 2.3 at the technical layer.

3.3 NORMATIVE EXTENSION REQUIREMENTS

The technical feasibility of the proposed framework is a necessary but not sufficient condition for its implementation in OPIN. In an ecosystem whose cryptographic algorithms are defined by formal normative instruments, PQC migration is also a first-order regulatory matter. Six normative gaps have been identified in the applicable instruments, with the corresponding extension requirement derived from each: absence of PQC profiles in ICPBrasil; absence of support for hybrid certificates and artefacts in the Participant Directory; absence of support for hybrid signatures in the SSA; restriction of the OPIN Technical Controls (Open Insurance Brasil, 2022) to classical algorithms; absence of references to PQC in the Security Manual; and absence of quantum cryptographic incident response mechanisms (Open Insurance Brasil, 2022; Superintendência de Seguros Privados (SUSEP), 2022; Open Insurance Brasil, 2021d, 2021b). The specificity of these extensions, derived from the instruments that govern

the ecosystem themselves, ensures their compatibility with the existing governance architecture, reflecting the normative dimension of crypto-agility discussed in Section 2.3: migration must be accommodated through controlled evolution of the regulatory framework, not structural replacement.

3.4 EXPERIMENTAL VALIDATION

The experimental validation of the proposed mechanisms will follow an approach based on prototyping and performance evaluation on representative operational flows of the OPIN ecosystem, taking as methodological reference the model established by Giron *et al.* (2024), who evaluated the impact of PQC and hybrid mechanisms on certificate infrastructure through controlled measurements of execution time and artefact size under comparable conditions.

The experimental environment will be configured with reference implementations of MLKEM and MLDSA made available by NIST (National Institute of Standards and Technology, 2024a, 2024b) and integrated with open-source cryptographic libraries with support for hybrid operations, namely OpenSSL and liboqs, the open-source library of the Open Quantum Safe Project with full support for NIST-standardised algorithms. The operational flows selected for evaluation correspond to the steps identified as Level 1 and Level 2 in the proposed taxonomy, as they present the highest performance impact on the ecosystem: TLS session establishment with ECDHE + MLKEM, issuance and verification of JWT and SSA with PS256 + MLDSA, and DCR execution over a hybrid mTLS channel.

The evaluation metrics cover three dimensions. The first is operational latency, measured as the execution time of each selected flow in classical, hybrid, and PQC-only modes, enabling quantification of the overhead introduced by the addition of post-quantum components. The second is the size of cryptographic artefacts, including JWT tokens, SSAs, and certificates, which directly affects the bandwidth and storage requirements of participants. The third is interoperability compatibility, verified through integration tests between implementations at different migration stages, validating that the hybrid model preserves the capacity for communication between classical and migrated participants.

The experimental results will be compared against the benchmarks established by Sadeghi *et al.* (2025) and Schardong *et al.* (2022) for regulated financial environments, enabling the performance of the proposed mechanisms to be situated within the state of the art and their adequacy to the operational requirements of OPIN to be assessed.

4 PARTIAL RESULTS AND RESEARCH TIMELINE

This chapter consolidates the partial results obtained in the scope of this research and situates the planned stages within the temporal horizon of the doctoral programme. The first section presents the two articles produced and their contributions to the research objectives. The second section details the research timeline, articulating the completed and planned stages through to the thesis defence.

4.1 PARTIAL RESULTS OBTAINED

Two articles have been produced in the scope of this research. The first establishes the theoretical foundation of the open paradigm that underpins the problem contextualisation presented in Chapter 1. The second partially corresponds to objectives SO1 and SO2, with the analytical sections consolidated with the supervisor and the propositional sections under development.

The first article, published in the IOSR Journal of Business and Management in July 2025 (Coelho; Custódio; Matos, 2025), establishes the theoretical foundation of the open paradigm through a systematic literature review conducted according to the PRISMA 2020 protocol. From a base of 2,497 identified documents, 274 studies were included in the synthesis after application of eligibility criteria. The article identifies five pillars that characterise mature open ecosystems: inclusion, interoperability, innovation, security, and consumer empowerment, examining their interdependencies in cross-sectoral contexts. The principal contribution is the characterisation of security as a structural condition for the other pillars: without adequate cryptographic guarantees, interoperability becomes a vector of exposure and data portability a systemic risk. This result underpins the central premise of the present work and supports the relevance of the analysis developed in the preceding chapters.

The second article, whose manuscript is in final stages of development, presents two complementary results. The first, of an analytical nature, is the characterisation of the structural security baseline of OPIN from the integrated analysis of its normative instruments and official technical specifications. This characterisation makes explicit the cryptographic dependencies, trust coupling points, and normative assumptions present in the eleven mandatory operational steps of the ecosystem, demonstrating that nine of these steps incorporate classical public-key primitives as a structural condition of functioning. The second result, of a propositional nature, is the derivation of a PQC transition framework adapted to the regulatory, institutional, and interoperability constraints of the ecosystem, comprising a three-level migration urgency taxonomy, a phased transition model with hybrid cryptography, and six normative extension requirements for ICPBrasil and the OPIN Participant Directory, derived directly from the applicable regulatory instruments. The analytical sections of the article, corresponding to objectives

SO1 and SO2, have been consolidated with the supervisor. The propositional sections, corresponding to objectives SO3, SO4, and SO5, are under development.

4.2 RESEARCH TIMELINE

The research is structured over four years, from August 2024 to August 2028, organised into stages that reflect the natural progression of a doctoral work in computational security: from literature review and problem characterisation to formal protocol design, experimental validation, and thesis writing.

Table 2 – Research timeline.

Period	Stage	Status
Aug–Dec 2024	Literature review, mandatory coursework, problem delimitation	Completed
Jan–Jul 2025	Article 1: systematic review of the open paradigm (published Jul/2025)	Completed
Aug–Dec 2025	Article 2: OPIN Background and Baseline (sections consolidated with supervisor) (SO1, SO2)	Completed
Jan–Jun 2026	Article 2: vulnerability analysis and proposed framework (SO3, SO5)	In progress
Jun 2026	Seminário de Andamento de Doutorado (SAD)	Planned
Jul–Dec 2026	Article 2 finalisation and submission; protocol design initiation	Planned
Feb 2027	Exame de Qualificação de Doutorado (EQD)	Planned
Jan–Jun 2027	Formal design of the hybrid protocol (SO4)	Planned
Jul–Dec 2027	Implementation, prototyping, and experimental evaluation (SO6)	Planned
Jan–Jun 2028	Article 3; thesis writing	Planned
Aug 2028	Thesis defence	Goal

Source: Elaborated by the author.

The timeline reflects two aspects relevant to the examining committee. The first is that objectives SO1 and SO2 are substantially completed, with results consolidated in the second article. The second is that objectives SO3, SO4, SO5, and SO6 have clearly delimited and achievable stages within the regulatory deadline, with sufficient margin for thesis writing and defence.

REFERENCES

- BANEGAS, Gustavo; BERNSTEIN, Daniel J.; HOOF, Iggy van; LANGE, Tanja. Concrete Quantum Cryptanalysis of Binary Elliptic Curves. **IACR Transactions on Cryptographic Hardware and Embedded Systems**, v. 2021, n. 1, p. 451–472, 2021.
- BERNSTEIN, Daniel J.; BUCHMANN, Johannes; DAHMEN, Erik (eds.). **Post-Quantum Cryptography**. [S. l.]: Springer, 2009.
- BRASIL. **Lei n.º 13.709, de 14 de agosto de 2018 — Lei Geral de Proteção de Dados Pessoais (LGPD)**. [S. l.: s. n.], 2018.
- CAMPBELL, Robert. Enterprise Migration to Post-Quantum Cryptography: Timeline Analysis and Strategic Frameworks. **Computers**, v. 15, n. 1, p. 9, 2025.
- CHENG, Adrian; JOSEPH, Simon; PHAM, Duc; MOSCA, Michele. Harvest Now, Decrypt Later: A Temporal Cybersecurity Risk in the Quantum Transition. **Telecom**, v. 6, n. 4, p. 100, 2025.
- COELHO, Luciano Figueiredo; CUSTÓDIO, Ricardo Felipe; MATOS, Manuel. The Open Paradigm: A Systematic Analysis of Evolutionary Frameworks and Cross-Sectoral Applications in Data-Driven Ecosystems. **IOSR Journal of Business and Management**, v. 27, n. 7, p. 42–77, 2025. Series 5.
- CONSELHO NACIONAL DE SEGUROS PRIVADOS (CNSP). **Resolução CNSP n.º 415, de 20 de julho de 2021**. [S. l.: s. n.], 2021.
- EUROPEAN UNION AGENCY FOR CYBERSECURITY (ENISA). **Post-Quantum Cryptography: Current State and Quantum Mitigation**. [S. l.], 2021.
- GIRON, Alexandre Augusto; SCHARDONG, Frederico; PERIN, Lucas Pandolfo; CUSTÓDIO, Ricardo; VALLE, Victor; MATEU, Victor. Automated Issuance of Post-Quantum Certificates: a New Challenge. *In: APPLIED Cryptography and Network Security (ACNS 2024)*. [S. l.]: Springer, 2024. (Lecture Notes in Computer Science).
- GROVER, Lov K. A Fast Quantum Mechanical Algorithm for Database Search. *In: PROCEEDINGS of the 28th Annual ACM Symposium on Theory of Computing*. [S. l.]: ACM, 1996. p. 212–219.
- HARDT, Dick. **The OAuth 2.0 Authorization Framework**. [S. l.], 2012.
- JONES, Michael; BRADLEY, John; SAKIMURA, Nat. **OpenID Connect Core 1.0**. [S. l.], 2014.
- MOSCA, Michele. Cybersecurity in an Era with Quantum Computers: Will We Be Ready? **IEEE Security & Privacy**, v. 16, n. 5, p. 38–41, 2018.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard**. [S. l.], 2024.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **FIPS 204: Module-Lattice-Based Digital Signature Standard**. [S. l.], 2024.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **FIPS 205: Stateless Hash-Based Digital Signature Standard**. [S. l.], 2024.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. **NIST SP 1800-38B: Migration to Post-Quantum Cryptography (Preliminary Draft)**. [S. l.], 2023.

OPEN INSURANCE BRASIL. **Controles Técnicos de Segurança da Informação, Versão 3.2**. [S. l.: s. n.], 2022.

<https://br-openinsurance.github.io/areadesenvolvedor/>.

OPEN INSURANCE BRASIL. **Diretório de Participantes**. [S. l.: s. n.], 2021.

<https://br-openinsurance.github.io/areadesenvolvedor/>.

OPEN INSURANCE BRASIL. **Diretrizes Técnicas de Certificação**. [S. l.: s. n.], 2021.

<https://br-openinsurance.github.io/areadesenvolvedor/>.

OPEN INSURANCE BRASIL. **Padrão de Certificados Digitais**. [S. l.: s. n.], 2021.

<https://br-openinsurance.github.io/areadesenvolvedor/>.

OPEN INSURANCE BRASIL. **Processo de Segurança do Open Insurance**.

[S. l.: s. n.], 2021. <https://br-openinsurance.github.io/areadesenvolvedor/>.

OPEN INSURANCE BRASIL. **Visão Geral do Ecossistema**. [S. l.: s. n.], 2021.

<https://br-openinsurance.github.io/areadesenvolvedor/>.

OPENID FOUNDATION. **Financial-grade API Security Profile 1.0**. [S. l.], 2021.

PROOS, John; ZALKA, Christof. Shor's Discrete Logarithm Quantum Algorithm for Elliptic Curves. **Quantum Information and Computation**, v. 3, n. 4, p. 317–344, 2003.

RESCORLA, Eric. **The Transport Layer Security (TLS) Protocol Version 1.3**. [S. l.], 2018.

SADEGHI, Somayeh; CHOUHAN, Vikas; ALDARWBI, Mohammed; GHORBANI, Ali; CHOW, Aaron; BURKO, Robby. Securing Financial Sector Applications in the Quantum Era: A Comprehensive Evaluation of NIST's Recommended Algorithms Through Use-Case Analysis. **Expert Systems with Applications**, v. 288, p. 128243, 2025.

SCHARDONG, Frederico; CUSTÓDIO, Ricardo; PEREIRA, Daniel; CASTONGUAY, Ivo. Post-Quantum Electronic Identity: Adapting OpenID Connect and OAuth 2.0 to the Post-Quantum Era. *In*: CRYPTOLOGY and Network Security (CANS 2022). [S. l.]: Springer, 2022. v. 13641. (Lecture Notes in Computer Science), p. 371–390.

SHOR, Peter W. Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer. **SIAM Journal on Computing**, v. 26, n. 5, p. 1484–1509, 1997.

STEBILA, Douglas; FLUHRER, Scott; GUERON, Shay. **Hybrid Key Exchange in TLS 1.3**. [S. l.], 2025. draft-ietf-tls-hybrid-design-16.

SUPERINTENDÊNCIA DE SEGUROS PRIVADOS (SUSEP). **Circular SUSEP n.º 635, de 20 de julho de 2021**. [S. l.: s. n.], 2021.

SUPERINTENDÊNCIA DE SEGUROS PRIVADOS (SUSEP). **Circular SUSEP n.º 638, de 27 de julho de 2021**. [S. l.: s. n.], 2021.

SUPERINTENDÊNCIA DE SEGUROS PRIVADOS (SUSEP). **Manual de Segurança do Open Insurance, Versão 1.2**. [S. l.: s. n.], 2022.
<https://br-openinsurance.github.io/areadesenvolvedor/>.